</> codigo.py

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 7s >

This file is malware.

It is a self-propagating SSH worm / botnet installer designed for unauthorized scanning, credential stuffing, remote code execution, persistence, and lateral movement.

1. **Deployment and persistence**
   - Requires root.
   - Creates hidden-looking directories: `/usr/lib/.sysd-scan/`, `/var/lib/.sysd-data/`, `/usr/lib/.sysd-monitor`.
   - Installs two systemd services (`scan-runner.service` and `file-monitor.service`) that restart automatically.
   - Creates Python virtual environments, installs `paramiko`, `tqdm`, `requests`, and system packages (`masscan`, `screen`, etc.).
   - Downloads configuration files and additional installers from `del.sou.pp.ua`.
   - After successful deployment, the script deletes itself.
2. **Scanning component (`run_scan.sh` + supporting scripts)**
   - Continuously runs `masscan` against IP ranges (downloaded from the C2) on ports 22 and 5522.
   - Extracts open hosts, filters previously seen ones, then launches multi-threaded SSH brute-force attempts.
   - Hardcoded credentials tried: `root:LeitboGi0ro` and `root:123@@@`.
   - Successful logins are written to result files in `/var/lib/.sysd-data/`.
3. **Propagation / infection component (monitor script)**
   - Watches the result files.
   - For each successful target, connects via SSH using the same weak passwords.
   - Uploads a copy of itself (`bendi.py`) to `/tmp/` on the victim.
   - Ensures Python is installed on the victim, then executes the payload.
   - The payload is this same installer, so the newly compromised host becomes another scanner/propagator.
   - Uses a central API (`https://sou.pp.ua/check_ip.php` and `add_ip.php`) to avoid re-infecting the same hosts.

- Sends detailed Telegram notifications (bot token and chat ID are hardcoded) reporting successful infections, including credentials used and status of each step.

4. **Additional malicious behavior**
   - Installs “Komari Agent” and a “tm” (traffmonetizer-style) component from the same C2 domain.
   - Uses `screen` sessions and timeouts to keep scanning resilient.
   - Attempts to force-clear apt/dpkg locks if needed to ensure installation succeeds.
   - Runs indefinitely in loops with automatic restart via systemd.

This is **not** a legitimate scanning or monitoring tool. It is designed to:

- Discover internet-facing SSH servers,
- Brute-force weak/default credentials,
- Infect them with a copy of itself,
- Maintain persistence,
- Report back to a C2 (Telegram + custom API),
- Expand the botnet automatically.

It exhibits classic worm behavior (self-replication via network), credential stuffing, remote code execution, and C2 communication.

Verdict: Malware (SSH worm / botnet loader).

Do not execute it. If it has already been run on a system, treat that system as compromised: isolate it, investigate for additional implants, rotate all credentials, and perform a full forensic review.

Qual é a categoria principal deste malware?

Worked for 7s >

Categoria principal: Worm (verme de rede / SSH worm)

Mais especificamente, trata-se de um **SSH worm** (ou network worm focado em SSH) com características de bot/botnet loader.

- Ele se **replica automaticamente** de um host comprometido para outros, sem intervenção humana.
- O ciclo é clássico de worm:
  1. Escaneia a internet (masscan em ranges de IP).
  2. Tenta autenticação SSH com senhas fracas/hardcoded.

3. Em caso de sucesso, sobe e executa uma cópia de si mesmo no alvo.
4. O novo host infectado passa a escanear e infectar outros.

- Usa persistência via systemd + notificação para C2 (Telegram + API central) para coordenar a campanha.

- **Botnet malware / Bot loader** — os hosts infectados formam uma rede controlada e reportam para o operador.
- **Credential stuffing / Brute-force tool** — componente de ataque, mas não é a finalidade final.
- **Trojan/Installer** — o script de instalação inicial tem comportamento de dropper, mas o objetivo real é a propagação.

Resumo: a classificação principal e mais precisa é **Worm** (SSH worm / self-propagating network worm).

↘ Qual a categoria principal do malware

↘ Como ele se replica automaticamente?

↘ Quais são as características do malware?